Parapet: Security Self-Assessment

2026 Shenzhen International FinTechathon, International Track, Topic E

Team: Oneshot

Date: 20 October 2026

1. Scope

This assessment covers the Parapet sandbox prototype (v0.1.0): the agent orchestration, the Counterparty Verification Protocol (CVP), the permission-tier policy engine, the risk scorer, the audit log, and the optional language-model explanation layer. It does not cover a production bank integration, which is described as a target architecture only.

2. Permission-tier implementation

2.1 Tiers

Tier	Name	Permitted actions	Owner interaction
0	Observe	Read invoices and history; write audit entries; send alerts	Owner acts manually
1	Recommend	Tier 0 plus propose a specific action with reasons	Owner acts manually
2	Prepare	Tier 1 plus draft the action (transfer order, reminder, financing application)	Owner approves with one tap
3	Execute	Tier 2 plus execute autonomously within caps and below the risk threshold	Owner informed after the fact

The tier is set per direction (`payable_tier`, `receivable_tier`) so an owner can, for example, let the agent negotiate receivables autonomously while keeping payables at tier 2.

2.2 Hard limits that no tier can override

Implemented in `policy.resolve` and evaluated before the tier is consulted:

1. **Failed or missing counterparty verification results in HELD.** Applies whenever payee details are new or changed. Unreachable counterparty is treated as failure.

2. **Risk score at or above `risk_hold_threshold` (default 0.45) results in ESCALATED.** A successful handshake can downgrade this to PREPARED (owner approval) but never to EXECUTED.
3. **Per-transaction cap** (default IDR 25,000,000) and **daily cap** (default IDR 60,000,000). Exceeding either downgrades EXECUTE to PREPARED.
4. **Only EXECUTED touches the ledger.** All other decisions are side-effect free apart from audit entries and owner messages.

2.3 Verification of the implementation

The test suite (`tests/test_parapet.py`, 12 tests) demonstrates:

- A business-email-compromise invoice is held and the balance is unchanged (`test_bec_invoice_is_held_and_no_money_moves`).
- An impostor's "confirmed" reply fails signature verification (`test_impostor_signature_fails_verification`).
- A legitimate bank change with a valid signature is routed to owner approval, not auto-paid (`test_legitimate_bank_change_is_prepared_not_held`).
- No counterparty agent available results in HELD (`test_no_handshake_available_means_hold`).
- Per-transaction and daily caps downgrade execution (`test_per_transaction_cap_downgrades_to_prepared`, `test_daily_cap_is_enforced_across_invoices`).
- Tier 0 never executes (`test_observe_tier_never_executes`).
- Agreed receivable terms carry a verifiable buyer signature (`test_negotiation_reaches_signed_agreement`).
- Audit chain detects tampering (`test_chain_is_valid_and_detects_tampering`).

3. Security controls

Control	Implementation	Status
Cryptographic payee verification	HMAC-SHA256 over canonical JSON including invoice id, amount, currency, bank, account number and nonce; constant-time comparison	Implemented
Replay protection	Random 64-bit nonce per challenge and per proposal	Implemented
Fail-closed defaults	Unknown payee, unreachable agent, invalid signature all produce HELD	Implemented
Model isolation	LLM receives only the decided outcome and signals; its output is text to the	Implemented

Control	Implementation	Status
	owner, never a decision or a tool call	
Prompt-injection resistance	Invoice body text never reaches the policy engine as instructions; it is only pattern-matched for risk signals	Implemented
Spending caps	Per transaction and per day, checked before execution	Implemented
Data minimisation in logs	Account numbers masked to last four digits in audit entries and messages	Implemented
Tamper-evident audit	SHA-256 hash chain with `verify_chain()`	Implemented
Non-repudiation of agreed terms	Buyer signature stored with agreed settlement payload	Implemented
Key management	Shared secret per counterparty in the sandbox	Sandbox only, see risk R1
Transport security	Not applicable in sandbox (in-process calls)	Production requirement
Authentication of the owner	Not implemented in sandbox	Production requirement

4. Known-risk list

ID	Risk	Likelihood	Impact	Mitigation in prototype	Required for production
R1	Shared HMAC secret compromised at the counterparty, allowing an attacker to sign a fraudulent payee attestation	Medium	High	Secret never travels with invoices; challenge includes exact amount and account so a stolen secret still cannot redirect a different payment silently	Asymmetric keys bound to KYB identity, issued and rotated by the bank; hardware-backed signing for larger counterparties
R2	Counterparty has no agent, so every	High	Medium	HELD routes to a clear manual step	Bank-hosted attestation endpoint

ID	Risk	Likelihood	Impact	Mitigation in prototype	Required for production
	bank change is HELD and the owner is burdened			(phone the number on file)	vouching for registered accounts, so suppliers need no software
R3	Risk weights produce false positives (legitimate invoices delayed)	Medium	Medium	Verified handshake downgrades escalation to one-tap approval rather than a hold	Calibrate weights on labelled fraud and default data; per-owner tuning
R4	Risk weights produce false negatives (novel fraud pattern scores low)	Medium	High	Any account change triggers the handshake regardless of score; caps bound the loss on any single execution	Add anomaly models on the bank's data as additional signals; never remove the handshake gate
R5	Prompt injection via invoice text aimed at the explanation model	Medium	Low	Model cannot change decisions or call tools; worst case is a misleading message to the owner	Output filtering; show the deterministic signal list alongside any model text (already done)
R6	Insider or owner-side compromise raising the tier and caps	Low	High	Not addressed in sandbox	Strong owner authentication, step-up auth for policy changes, policy-change entries in the audit log,

ID	Risk	Likelihood	Impact	Mitigation in prototype	Required for production
					cooling-off period for cap increases
R7	Negotiation agent conceding too much on receivables	Low	Medium	Hard 14-day ceiling and maximum three rounds; terms always require buyer signature	Owner-configurable ceiling and partial-payment rules
R8	Audit log stored where the agent itself could rewrite it	Medium	Medium	Hash chain makes rewriting detectable	Write-once storage or anchoring the chain head to an external timestampin g service
R9	Financing recommenda tion steering the owner toward unsuitable credit	Low	Medium	Recommenda tion only, with the specific receivable and reason stated	Suitability checks against the bank's SME credit policy before any pre-filled application
R10	Denial of service on the handshake (counterpart y endpoint flooded so payments are held)	Low	Medium	Fail-closed means attacker can delay, not steal	Rate limiting, retries with backoff, and a bank-hosted fallback attestation source

5. Compliance considerations

- **Explainability:** every decision carries its signal list and reason; the owner message repeats them. Suitable for consumer-protection expectations around automated decisions.
- **Human in the loop:** tiers 0 to 2 keep the owner as the decision maker; tier 3 is bounded by caps and the risk threshold and can be revoked at any time.

- **Data protection:** account numbers are masked; no personal data beyond business contact details is processed in the sandbox.
- **Auditability:** the hash-chained log is designed for examination by the bank's compliance function or a regulator.

6. Conclusion

The prototype implements the full permission-tier model with hard limits that tiers cannot override, a cryptographic verification gate for payee changes, a fail-closed posture, model isolation from the decision path, and a tamper-evident audit trail. The principal gaps for production are key management bound to verified identity, owner authentication, and calibration of risk weights on real data; all three are listed above with their mitigations.